

NAME: THULASI.S

DATE: 15.04.26

ROLL.NO:241901118

EXPERIMENT 12

INTRUSION DETECTION

AIM:

To understand the concept of an Intrusion Detection System (IDS) and analyze network traffic to identify suspicious or malicious activities using practical techniques in the TryHackMe *Intrusion Detection* room.

ALGORITHM:

1. Load the network traffic file (PCAP)
2. Open the file using a packet analysis tool (e.g., Wireshark)
3. Apply filters to view specific traffic (IP, port, protocol)
4. Examine packets for unusual or suspicious activity
5. Compare traffic patterns with known attack signatures
6. Identify possible intrusion attempts (e.g., scanning, brute force)
7. Note important details (IP address, port, protocol)
8. Answer the given questions based on analysis

Task 1 Introduction

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source IDS can be combined to provide a per-user breakdown, and scoring of all the IDS alerts created during the course of a CTF.

You can access the system by navigating to http://MACHINE_IP:8000/register.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at http://MACHINE_IP:8000, in preparation for future tasks.

No answer needed

Correct Answer

Task 2 Intrusion Detection Basics

Intrusion detection systems (IDS) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a firewall, anti-virus, or authorisation

system may prevent certain activity from occurring on or against IT assets, an IDS will instead monitor activity that isn't restricted and sort the malicious from the benign. IDS commonly apply one of two different detection methodologies; Signature (or rule) based IDS will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based IDS establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

Either way, once an incident is detected, the IDS will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like Graylog or the ELK Stack. Some IDS may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based IDS are attached to this demo; Suricata, a network-based IDS (NIDS), and Wazuh, a host-based IDS (HIDS). Both of these IDS implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?

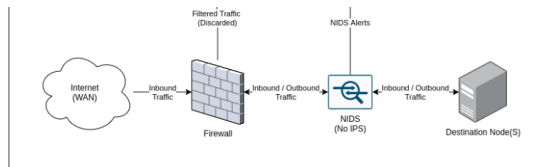
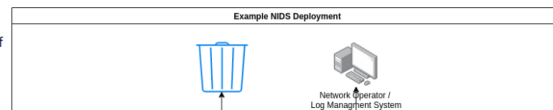
signature-based detection

✓ Correct Answer

Task 3 Network-based IDS (NIDS)

As the name implies, network intrusion detection systems or NIDS monitor networks for malicious activity by checking packets for traces of activity associated with a wide variety of hostile or unwanted activity including:

- Malware command and control
- Exploitation tools
- Scanning
- Data exfiltration
- Contact with phishing sites
- Corporate policy violations



Network-based detection allows a single installation to monitor an entire network which makes NIDS deployment more straightforward than other types. However, NIDS are more prone to generating false positives than other IDS, this is partly due to the sheer volume of traffic that passes through even a small network and, the difficulty of building a rule set that is flexible enough to reliably detect malicious traffic without detecting safe applications that may leave similar traces. This can be alleviated somewhat, by tuning the IDS to only enforce rules that would be considered abnormal traffic for any particular network however, this does take some time as the IDS must be deployed on a network for a while in order to establish what traffic is normal.

NIDS can be deployed on both sides of the firewall though, they tend to be deployed on the LAN side as there is limited value in detecting attacks that occur against outside nodes as they will be under attack constantly. A NIDS may also feature some form of intrusion prevention (IPS) functionality and be able to block nodes that trigger a set number of alerts, this is not always enabled as automated blocking can conflict with a high false-positive rate. Note, that NIDS rely on having access to all of the communication between nodes and are thus affected by the widespread adoption of in-transit encryption.

A variety of open source and proprietary NIDS exist, the node in this scenario is protected by the open source NIDS, Suricata. For this, demo the IPS mode is disabled so you are free to run as many attacks as you want. In fact, try and run some of your favourite tools against the target and see how the different IDS respond. A history of all the alerts generated during this room is available at http://MACHINE_IP:8000/alerts

Answer the questions below

What widely implemented protocol has an adverse effect on the reliability of NIDS?

TLS

✓ Correct Answer

Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?

No answer needed

✓ Correct Answer



Task 4 Reconnaissance and Evasion Basics

Now that the basics of NIDS have been covered, it's time to discuss some simple evasion techniques in the context of the first stage of the cyber kill chain, reconnaissance. First, run the following command against the target at MACHINE_IP

```
nmap -sV MACHINE_IP
```

I recommend completing this [room](#) if you're unfamiliar with `nmap`. In simple terms, the above command will retrieve a detailed listing of the services attached to the targeted node by performing a number of predefined actions against the target. As an example, `nmap` will request long paths from HTTP servers to deliberately create 404 errors some HTTP servers will provide additional information when a 404 error is triggered.

The above command does not make use of any evasion techniques and as a result, most NIDS should be able to detect it with no issue, in fact, you should be able to verify this now by navigating to MACHINE_IP:8000/alerts. Suricata should have detected that some packets contain the default `nmap` user agent and triggered an alert. Suricata will have also detected the unusual HTTP requests that `nmap` makes to trigger responses from applications targeted for service versioning. Wazuh may have also detected the 400 error codes made during the course of the scan.

We can use this information to test our first evasion strategy. By appending the following to change the user_agent `http.useragent=<AGENT_HERE>`, we can set the user agent used by `nmap` to a new value and partially evade detection. Try running the command now, a big list of user agents is available [here](#). The final command should look something like this:

```
nmap -sV --script-args http.useragent="<USER AGENT HERE>" MACHINE_IP
```

Conversely, if you're scanning an important database behind a corporate firewall that should never be accessed from the outside, a single IDS alert is likely to be the cause of some alarm. Note that, the scoring system does take this into account so the results you see for attacks against the target web server will be reduced when compared with the assets that will be attacked later in this room (the scoring system works somewhat like Golf so a higher score is worse).

We should also consider the exact definition of evasion as applied to IDS; it can either be complete, where no IDS alerts are triggered as a result of hostile actions, or, partial where an alert is triggered but, its severity is reduced. In some scenarios, complete evasion may be the only option for example, if valuable assets are involved. In other cases partial evasion may be just as good as low severity IDS alerts particularly from NIDS are much less likely to be investigated, or even forwarded further up the alert management chain. Again, this is reflected by the scoring system as it will take the reliability of each of the attached IDS into account when scoring alerts.

Answer the questions below

What scale is used to measure alert severity in Suricata? (*-*)

1-3

✓ Correct Answer



How many services is nmap able to fully recognise when the service scan (-sV) is performed?

3

✓ Correct Answer



Task 5 Further Reconnaissance Evasion

Of course, `nmap` is not the only tool that features IDS evasion tools. As an example the web-scanner `nikto` also features a number of options that we will experiment with within this task, where we perform more aggressive scans to enumerate the services we have already discovered. In general, `nikto` is a much more aggressive scanner than `nmap` and is thus

operators by flooding the system with alerts from many hosts and attack vectors and thus conceal the real attack. This strategy may also simply crash any IDS that's protecting the service if enough packets are sent though, most IDS use some form of throughput limiter. In fact, I've adjusted the limiter in Wazuh to output as fast as possible for this CTF otherwise, it would take too long to process all of the alerts generated by aggressive scans.

More practical options from the field of open-source intelligence may also be available and will be covered in the next task.

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

✓ Correct Answer



Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

✓ Correct Answer



Task 6 Open-source Intelligence

Continuing, from the sonar analogy from earlier, if `nmap` and other scanners are active sonar, then open-source intelligence or OSINT is passive sonar as intelligence is gained not from

- The technologies used to host the site may be acquired from error pages, file extensions, debug pages, or the server tag used in an HTTP response
- Additional information on the tools used by the target may be available in job listings

For this demo, have a look around the "public" facing site and see how much information you can acquire.

Answer the questions below

What version of Grafana is the server running?

✓ Correct Answer



What is the ID of the severe CVE that affects this version of Grafana?

✓ Correct Answer



If this server was publicly available, What site might have information on its services already?

✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

✓ Correct Answer

Task 7 Rulesets

```
python3 exploit.py -u MACHINE_IP -p 3000 -f <REMOTE FILE TO READ>
```

See what you can find on the server, remember that the exploit, gives us access to the same privileges of the user that's running the service. Once you're happy with what you've found on the server have a look at the IDS alert history at `MACHINE_IP:8000/alerts`. Can you see any evidence that this particular exploit was detected? like I said not all rule sets are perfect.

Answer the questions below

What is the password of the grafana-admin account?

✓ Correct Answer



Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)

✓ Correct Answer



Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

✓ Correct Answer



Task 8 Host Based IDS (HIDS)

Not all forms of malicious activity involve network traffic that could be detected by a NIDS, ransomware, for example, could be disturbed via an external email service provider installed and executed on a target machine and, only be detected by a HIDS once, it calls home with messages of its success which, of course, is way too late. For this reason, it is often advisable to deploy a host-based IDS alongside a NIDS to check for suspicious activity that occurs on devices and not just over the network including:

Wazuh should be able to detect that an insecure SSH connection attempt was made to the server but will not mention the connection to the HTTP server, unlike Suricata. However, if we run:

```
nmap --script=vuln MACHINE_IP
```

Wazuh will create thousands of alerts as it will detect each 400 error code created as a result of running the vuln script as this attack creates entries in the error log which, is one of the sources that Wazuh reads from if it has been configured too.

Answer the questions below

What category does Wazuh place HTTP 400 error codes in?

✓ Correct Answer



Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

✓ Correct Answer

Task 9 ✓ Privilege Escalation Recon

Now, that an initial foothold has been established it's time to discuss how IDS can track privilege escalation. This is primarily a task for HIDS as many post-exploitation tasks like, privilege escalation do not require communication with the outside world and are hard or impossible to detect with a NIDS. In fact, privilege escalation is our first task as we are not yet root. The first step in privilege escalation is usually checking what permissions we currently have this, could save us a lot of work if we're already in the sudo group. There are a few different ways to check this including:

Of course, this activity isn't completely invisible as linpeas would likely be detected by an antivirus if one was installed though, there are ways to reduce its footprint. There is also the question of transporting the script to the target system, Suricata is capable of detecting when scripts are downloaded via wget, however, TLS restricts its ability to actually detect the traffic without the deployment of web proxy servers. It may also be possible to simply copy and paste the script's content however, most HIDS implement some form of file system integrity monitoring which would detect the addition of the script even if an antivirus was not installed, more on this later.

Either way, linpeas should be able to identify a potential privilege escalation vector.

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

✓ Correct Answer



Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

✓ Correct Answer



Task 10 ✓ Performing Privilege Escalation

The last task allowed us to identify Docker as a potential privilege escalation vector. Now it's time to perform the escalation itself. First, though, I should explain how this particular privilege escalation works. In short, this attack leverages a commonly suggested [workaround](#) that allows non-root users to run docker containers. The workaround requires adding a non-privileged user to the docker group which, allows that user to run containers without using sudo or having root privileges. However, this also grants effective root-level privileges to the provided user, as they are able to spawn containers without restriction.

is monitored by Wazuh. In this case, we can perform this by running:

```
echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >>/mnt/etc/sudoers
```

- We could add a new user to the system and join the root group via /etc/passwd. Again though, this activity is likely to be noticed by the HIDS

Try a few of these options and note the resultant IDS alerts.

Answer the questions below

Perform the privilege escalation and grab the flag in /root/

✓ Correct Answer

Task 11 ✓ Establishing Persistence

The compromised host is running Linux so we have a number of persistence mechanisms available to us. The first option which, is arguably the most straightforward is to add a public key that we control to the authorized_keys file at /root/.ssh/. This would allow us to connect to the host via SSH without needing to run the privilege escalation exploit every time and without relying on the password for the compromised account not changing. This methodology is very common among botnets as it's both reliable and very simple to implement as pretty much all Linux distributions intended for server use run an OpenSSH service by default.

Try this now, a valid key pair can be generated for the attack box by running ssh-keygen. Once this key is added to the authorized_keys file in /root/.ssh/ you should be able to gain remote access to root whenever it's needed, simple right? Well, unfortunately, this tactic has one big disadvantage as it is highly detectable.

HIDS often feature some form of file system integrity monitoring service which, will periodically scan a list of target directories for changes with, an alert being raised every time a file is changed or added. By adding an entry to the authorized_keys file you would have triggered an alert of a fairly high severity and as a result, this might not be the best option. An alert is

Note that, the scoring system does take this into account so the results you see for attacks against the target web server will be reduced when compared with the assets that will be attacked later in this room (the scoring system works somewhat like Golf so a higher score is worse).

We should also consider the exact definition of evasion as applied to IDS; it can either be complete, where no IDS alerts are triggered as a result of hostile actions, or, partial where an alert is triggered but, its severity is reduced. In some scenarios, complete evasion may be the only option for example, if valuable assets are involved. In other cases partial evasion may be just as good as low severity IDS alerts particularly from, NIDS are much less likely to be investigated, or even forwarded further up the alert management chain. Again, this is reflected by the scoring system as it will take the reliability of each of the attached IDS into account when scoring alerts.

Answer the questions below

What scale is used to measure alert severity in Suricata? (*-*)

1-3

✓ Correct Answer



How many services is nmap able to fully recognise when the service scan (-sV) is performed?

3

✓ Correct Answer



Task 5 Further Reconnaissance Evasion

Of course, **nmap** is not the only tool that features IDS evasion tools. As an example the web-scanner **nikto** also features a number of options that we will experiment with within this task, where we perform more aggressive scans to enumerate the services we have already discovered. In general, **nikto** is a much more aggressive scanner than **nmap** and is thus harder to conceal; however, these more aggressive scans can return more useful information in some cases. Let's start by running **nikto** with the minimum options:

There are also more complex evasion options beyond clever usage of certain web scanner features; however, many of these options require additional resources that may simply not be available in or outside of a CTF environment. For example, if you were to somehow gain access to a large enough botnet it may be possible to simply overwhelm the target IDS or IDS operators by flooding the system with alerts from many hosts and attack vectors and thus conceal the real attack. This strategy may also simply crash any IDS that's protecting the service if enough packets are sent though, most IDS use some form of throughput limiter. In fact, I've adjusted the limiter in Wazuh to output as fast as possible for this CTF otherwise, it would take too long to process all of the alerts generated by aggressive scans.

More practical options from the field of open-source intelligence may also be available and will be covered in the next task.

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

/login

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

6

✓ Correct Answer



Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

6,A,B

✓ Correct Answer



Task 6 Open-source Intelligence

Information may also be gathered from the target site and related assets if they are publicly available including:

- The technologies used to host the site may be acquired from error pages, file extensions, debug pages, or the server tag used in an [HTTP](#) response
- Additional information on the tools used by the target may be available in job listings

For this demo, have a look around the "public" facing site and see how much information you can acquire.

Answer the questions below

What version of Grafana is the server running?

8.2.5

✓ Correct Answer



What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798

✓ Correct Answer



If this server was publicly available, What site might have information on its services already?

shodan

✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf

✓ Correct Answer



these other methods in conjunction with the docker-compose reverse shell as, backups.

Answer the questions below

Abuse docker to establish a backdoor on the host system

No answer needed

✓ Correct Answer

Task 12 ✓ Conclusion

I hope you've enjoyed this room and learned a few things. As previously mentioned this room was the first public test of the CTF scoring system project I've been developing. I have enclosed a link to the source code for the scoring system, it's licensed under AGPL-3.0 so feel free to modify it or add the system to your own CTF. There's documentation on installation and configuration available in the repo as well as links to prebuilt docker images.

Repo Link: <https://github.com/Jroo1053/CTFScore>

Thanks for playing.

Answer the questions below

Read the above

No answer needed

✓ Correct Answer

RESULT:

Successfully analyzed network traffic and identified potential intrusion attempts using IDS techniques.